Higher National Diploma in Network Engineering, Year 2
BSc (Hons) Ethical Hacking & Network Security, Year 2

PRINCIPLES OF INFORMATION SECURITY

Signatures, certificates and TLS



Day 4 - Morning

Running case: Taxila College, a fictional college

Niranga Dharmaratna
School of Computing & Engineering
National Institute of Business Management

Today

Prove who made a document, and whose key and whose site it is.

- Signing with the private key - 35 min
- Tampering breaks the signature - 30 min
- A certificate is a signed identity - 30 min
- The chain of trust - 30 min
- Transport security and the padlock - 30 min



Today serves one outcome

LO1 Explain the fundamentals of information security.

LO2 Discuss the key characteristics of cryptography and cryptographic systems.

LO3 Analyze the principles of encryption, decryption, hashing, and data integrity.

LO4 Outline the process of ensuring digital security.

LO5 Describe the fundamentals of threats and countermeasures.

LO6 Explain the fundamentals and process of business continuity planning.

Three things you already have

RECALL

A hash is a fingerprint that changes on any edit.

- A **key pair**: anyone can close a padlock only you can open
- **Accountability**: being able to prove who did something
- Today joins all three

Fingerprint + a key only you hold = proof of who made it.

Two problems of proof

- Employers **phone** the Registrar to check transcripts
- A message that seemed to come from the Registrar linked to a **look-alike** page
- Two staff typed their bank details there

Can a document prove who made it? Can a page prove whose it is?

T TAXILA

Transcripts an employer can verify without phoning the college.

R

REGISTRAR

I want an employer to check a transcript in seconds, without phoning my office.

The Registrar, on the fourth day of your placement.

CONCEPT 1

Signing with the private key

A transcript the Registrar signs so an employer can trust it without phoning the college.

TRY IT FIRST

Sign with the private key, verify with the public key.

35 min

Demonstration: sign, then verify

1. Make the Registrar's key pair
2. Hash a transcript line and sign the digest
3. Verify with the Registrar's public key
4. Verify with a stranger's public key instead

Only the matching public key verifies the signature.

How a signature is made and checked

RECALL

Non-repudiation means a person cannot later deny an action.

- **Sign**: hash the document, then sign the digest with your **private** key
- **Verify**: hash it again, check the signature with your **public** key
- Proves **origin** and **integrity**
- The document is **not** hidden

Encrypting and signing are different jobs

Encrypt to someone (Day 2)

- You use **their public** key
- They open it with **their private** key
- Gives secrecy: only they read it

Sign (today)

- You use **your private** key
- Anyone checks with **your public** key
- Gives proof, and no secrecy

Locking with your own private key never makes anything secret.

Digest, seal or signature

Day 3	Day 3	Today
A plain digest	**An HMAC seal**	**A signature**
Anyone can make it, and anyone can remake it.	Only the key-holders can make or check it.	Only the private-key holder can make it; anyone can check it.
Shows no change only if kept safe.	*Shows a key-holder made it, not which one.*	*Shows which person: non-repudiation.*

Only one person holds the private key, so only one person **could** have signed.

A seal only you can press

YOU ALREADY KNOW THIS

A wax seal pressed with a stamp only one official owns. Anyone recognises it; nobody else can make it.

MAPPING

the stamp only you own = your private key · **others recognising the seal =** verifying with your public key · **nobody else holds the stamp =** non-repudiation

T TAXILA

A transcript the Registrar signs so an employer can trust it without phoning the college.

× COMMON MISTAKE

Signing hides the document.

A signature proves who wrote it and that it is unchanged; it does not hide it.

CONCEPT 2

Tampering breaks the signature

An altered transcript no longer verifies against the Registrar's public key.

TRY IT FIRST

One edit and verification fails.

30 min

Demonstration: one edit, a broken signature

1. Sign the transcript, then change B to A
2. Add one invisible space, then change one digit
3. Put the original back
4. Re-sign the changed copy with another key

Any change, however small: verification fails.

Why one byte breaks it

RECALL

The avalanche effect: one changed character gives a completely different digest.

- The checker hashes the copy they received
- A changed copy gives a completely **different** digest
- It no longer matches the digest that was signed
- Nobody can repair it without the **private** key

A valid signature proves the document is unchanged since signing.

The cracked seal

- A failed check says **that** it changed, not **what** changed
- A signature still hides nothing: anyone can read the transcript

YOU ALREADY KNOW THIS

A letter arrives with its wax seal cracked. You may not know who opened it, but you know at once that it was opened.

MAPPING

the cracked wax = a failed verification · **you know the envelope was opened =** you know the file changed

T TAXILA

An altered transcript no longer verifies against the Registrar's public key.

CONCEPT 3

A certificate is a signed identity

The portal's certificate says the key really belongs to the taxila.example domain.

TRY IT FIRST

A certificate as a passport, field by field.

30 min

Whose public key is this?

RECALL

The key distribution problem is how to get a key safely to the other side.

- To check a signature, you need the signer's **public** key
- Anyone could publish a key and call it the Registrar's
- Every signature they made would then verify

We need someone we trust to say: this key belongs to this name.

Demonstration: a certificate is a passport

1. Open the certificate for `sis.taxila.example`
2. Read each field beside the passport page
3. Check the issuer's signature
4. Change one letter of the subject and check again

Change one field, and the stamp no longer matches.

An X.509 certificate, field by field

The certificate

- **Subject**: `sis.taxila.example`
- **Issuer**: who signed it
- **Validity**: first and last day
- **Public key**: the subject's key
- **Signature**: the issuer's, over all of it

The passport page

- Your name and photo
- The issuing government
- Date of issue and of expiry
- Your photo, linking page to face
- The official stamp

A certificate authority (CA) checks the name, then vouches for it by signing.

A signed statement of identity

- A certificate is **public**: on its own it keeps **nothing** secret

YOU ALREADY KNOW THIS

Border officers trust a stranger's passport because they trust its issuing government and can check its stamp.

MAPPING

your photo and name = the subject and public key · **the issuing authority =** the certificate authority · **the official stamp =** the authority's signature

T TAXILA

The portal's certificate says the key really belongs to the `taxila.example` domain.

CONCEPT 4

The chain of trust

A self-signed certificate on the portal makes the browser warn, and that warning is the lesson.

TRY IT FIRST

Walk end-entity to intermediate to root, then break a link.

30 min

Demonstration: follow the chain of trust

1. Build a chain of three certificates
2. Let the browser check each link
3. Remove the intermediate certificate
4. Serve a self-signed certificate instead

Any broken link, and the browser refuses.

From the site to a root you already hold

- **End-entity**: the site's certificate, signed by an intermediate
- **Intermediate**: signed by a root
- **Root**: already in your browser's **trust store**
- Roots stay offline; intermediates do the daily signing

Every link checks, and the chain ends at a root: trusted.

Vouched for, or vouching for itself

Signed by an authority

Its chain ends at a root in the trust store. The browser trusts the key and shows a padlock.

× Self-signed

The issuer is the subject itself. It is a valid certificate, but nobody vouches for it, so the browser warns.

Valid in form; trusted by nobody.

*On a website you did not make, a certificate warning means **stop**.*

Ask, expire, revoke

- A **certificate signing request (CSR)** carries the public key and the name, and asks an authority to sign
- Every certificate has an **end date**
- At the time of writing, a public certificate lasts at most **200 days**
- An authority can **revoke** a certificate early, for example after a key leaks

A letter from someone you trust

YOU ALREADY KNOW THIS

A reference letter counts because someone your employer trusts vouches for it. One you wrote yourself counts for nothing.

MAPPING

the letter = the certificate · **the trusted referee =** the root authority in your browser · **a stranger vouching for themselves =** a self-signed certificate

× COMMON MISTAKE

A certificate error is a browser bug to click past.

It means the identity could not be trusted; stop.

CONCEPT 5

Transport security and the padlock

The fake message linked to a look-alike page; a padlock there would still not make it Taxila.

TRY IT FIRST

What the padlock proves and what it does not.

30 min

Secure web is ordinary web inside TLS

RECALL

The hybrid pattern sets up a fast symmetric key, by carrying it or by agreeing it in the open.

- **HTTP**, the Hypertext Transfer Protocol, carries everything as plain text
- **HTTPS** is HTTP wrapped in **Transport Layer Security (TLS)**
- TLS 1.3 is current; 1.0 and 1.1 are **deprecated**

The handshake in four moves

1. Browser: hello, and its **public share**
2. Server: its share; both compute the same **session key**
3. Server: its certificate, and the handshake **signed**
4. Browser checks chain and signature; then all is **encrypted**

The session key is agreed in the open and never travels.

Demonstration: what the padlock proves

1. Read the plain-web capture of a form
2. Read the secure-web capture of the same form
3. Search both for the index number
4. Open the real portal, then the look-alike link

Two pages, two valid padlocks, one wrong name.

What the padlock proves, and what it does not

It proves

- The connection is encrypted
- An authority vouches that the key belongs to the name in the address

It does not prove

- That the name is the one you meant
- That the site is honest
- That the operator will look after your data

Read the name: the padlock vouches only for that name.

Three further protections

- **HTTP Strict Transport Security (HSTS)**: use only secure web from now on
- **Old versions retired**: no TLS 1.0 or 1.1 on a server
- **Certificate pinning**: an app accepts only its own server's key

YOU ALREADY KNOW THIS

A sealed diplomatic pouch is addressed to a verified office. But a sealed pouch sent to the wrong office is still sealed.

MAPPING

the seal = the encryption · **the verified address =** the certificate's identity · **a sealed pouch to the wrong office =** a valid padlock on a bad site

Common mistakes

× COMMON MISTAKE

Signing hides the document.

A signature proves who wrote it and that it is unchanged; it does not hide it.

× COMMON MISTAKE

A certificate error is a browser bug to click past.

It means the identity could not be trusted; stop.

× COMMON MISTAKE

The padlock means the site is trustworthy.

It proves an encrypted channel and a vouched identity, not a safe operator.

Before the next day

READ	**Security in Computing, section 2.3** Certificates, trust and digital signatures; then section 12.5.
PRACTICE	**A provincial land records office** Practice question 4: signatures, non-repudiation, self-signed against authority-signed.
PACK	**Evidence pack 4** After this afternoon's lab. *Due before the next teaching day.*

Questions & Discussion

This afternoon: sign your own file, read certificates, and see what secure web hides.



Disclaimer & Copyright

The information in this presentation is for general teaching purposes only. It is not comprehensive and is not professional advice; any reliance you place on it is at your own risk. I aim to keep it accurate, but I make no representations or warranties of any kind about its completeness, accuracy, reliability or suitability.

Security tools, standards and laws change. Versions, editions and commencement dates in this presentation were checked at the time of writing; check the current documentation before relying on them.

This presentation may refer to third-party websites or content. I do not endorse their views or information, and I am not responsible for their content.

Taxila College is fictional. Its campuses, people, systems and incidents were invented for teaching. Product and tool names, for example Kali Linux, VirtualBox, CyberChef and Wireshark, belong to their owners; this material is not affiliated with or endorsed by any of them.

Practise only on your own virtual machine, the module's provided files and application, and the portal's demos. Testing a system you do not own, without written permission, is an offence under Sri Lanka's Computer Crime Act, No. 24 of 2007.

© Niranga Dharmaratna, School of Computing & Engineering, National Institute of Business Management. Teaching content under CC BY-NC-SA 4.0; code and demonstrations under MIT; Open Sans under the SIL Open Font Licence.

Revision 213a31e